TASK: 31

(OWASP Mobile Top 10)

IOS Xcode setup, static analysis of IOS

&

SSL pinning by pass

Surendra Gabbani

What is an iOS IPA File?

An IPA (iOS App Store Package) file is the installation package for iOS applications.
It contains:

- Compiled app code
- Resources (images, assets, etc.)
- Info.plist
- Code signature

IPA files are used to install apps on iPhones/iPads and are similar to APK files in Android.

What is Xcode Tool?

Xcode is Apple's official Integrated Development Environment (IDE) used for developing:

- iOS apps
- macOS apps
- watchOS apps
- tvOS apps

It provides:

- Code editor
- Debugger
- Simulators
- Build tools
- Device logs
- Signing and provisioning profiles

In security testing, Xcode is helpful for:

- Inspecting IPA contents
- Reading logs
- Viewing app structure
- Analyzing code (if source is available).

What is Jailbreaking?

Jailbreaking is the process of removing Apple's software restrictions on iOS devices.
It allows the user to:

- Access the iOS file system
- Install unauthorized apps
- Bypass security sandbox restrictions
- Install hooks (Frida, objection, etc.)

Security testers use jailbroken devices for:

- Dynamic analysis
- Bypassing SSL Pinning
- Inspecting app files
- Viewing keychain data

Difference Between Jailbroken & Non-Jailbroken Device

Jailbroken Device

- Full filesystem access
- Can install custom tools (Frida, SSL Kill Switch, Cycript)
- Can hook/intercept app behavior
- Weaker security
- Useful for security testing

Non-Jailbroken Device

- Restricted filesystem
- No root privileges
- Cannot install unauthorized apps/tools
- Higher security
- Limited dynamic testing (needs proxy-based testing only

How do we perform Static Analysis of an IPA File?

Static analysis means analyzing the app without running it.

Steps:

1. Extract the IPA
    - Rename .ipa → .zip
    - Unzip to view the app bundle.
2. Analyze App Structure
   Check:
    - Payload/*.app
    - Info.plist
    - Certificates
    - Embedded frameworks
3. Inspect Info.plist for:
    - Insecure permissions
    - ATS settings (App Transport Security)
    - Background modes
4. Identify Third-Party Libraries
   Look for analytics, logging, or outdated SDKs.
5. Class-Dump / Hopper / IDA / Ghidra (No disallowed instructions)
   Used to inspect Objective-C class headers and binary code.
6. Check for Hard-coded Data
    - API keys
    - Secrets
    - URLs
    - Sensitive strings
7. Search for Weak Crypto
   Identify MD5, SHA1, weak algorithms (high-level review only).

What is SSL Kill Switch?

SSL Kill Switch is a security testing tweak used on jailbroken iOS devices to disable SSL certificate pinning inside apps so testers can intercept HTTPS traffic using Burp or Charles.

It helps in:

- Testing insecure communication
- Inspecting encrypted traffic
- Identifying sensitive data leaks

Only used for security testing on apps you own or have authorization to test.

Best Setup for iOS Pentesting:

- Real iPhone device.
- Jailbroken device (for advanced testing).
- Frida + Objection.
- Burp/Charles.
- Xcode + developer tools.
- MobSF for static analysis.

LAB PRACTICAL

Lab practical of IOS Static analysis in Kalilinux using mobsf

Lab IPA: https://github.com/prateek147/DVIA-v2/blob/master/DVIA-v2.ipa

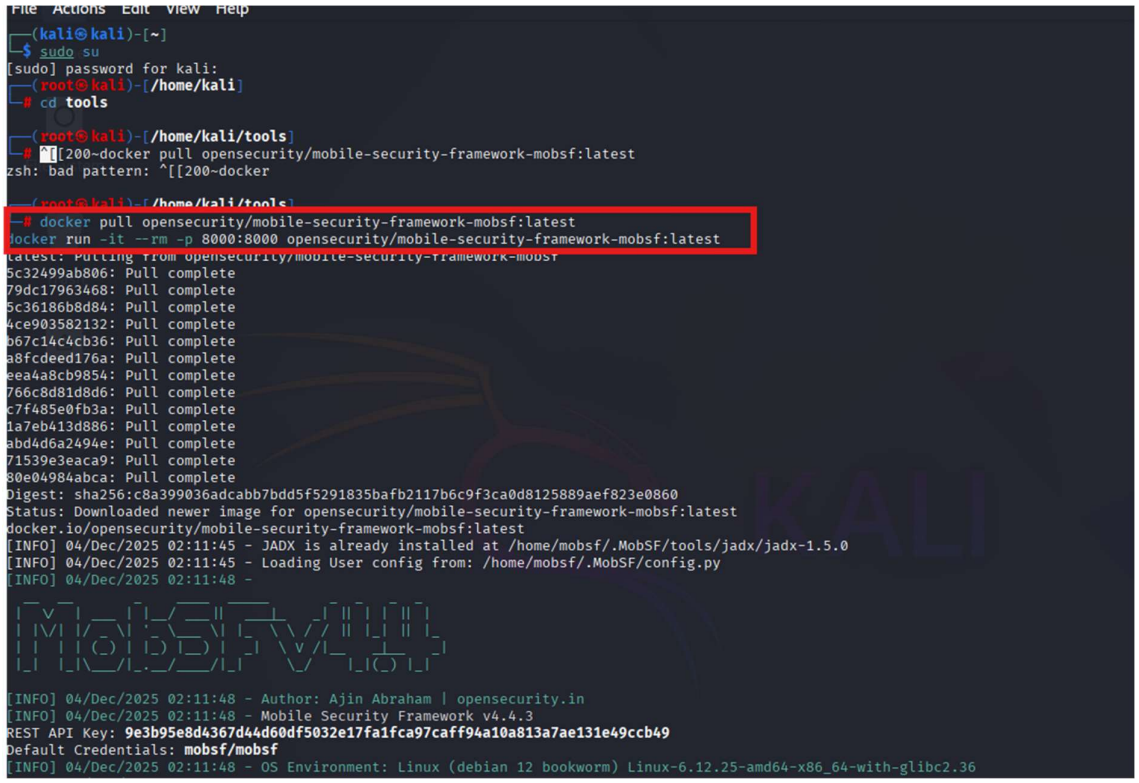
STEP 1:

• Open terminal in kali and run “superuser” command.

• setup with docker mobsf github using these commands and pull out.

docker pull opensecurity/mobile-security-framework-mobsf:latest

docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-mobsf:latest



STEP 2:

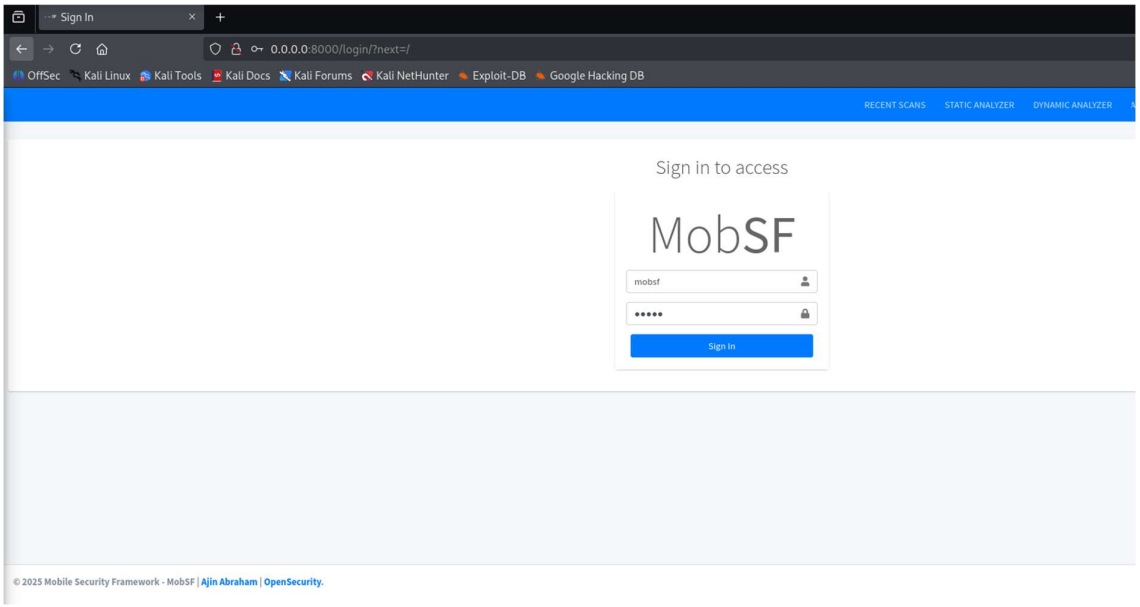
- Run the Mobsf with given port number in “8000”.
- Copy and paste that Http port URL in kali browser.

```
[INFO] 04/Dec/2025 02:12:07 - Checking for Update.
[INFO] 04/Dec/2025 02:12:08 - No updates available.
[2025-12-04 02:12:08 +0000] [1] [INFO] Starting gunicorn 23.0.0
[2025-12-04 02:12:08 +0000] [1] [INFO] Listening at: http://0.0.0.0:8000 (1)
[2025-12-04 02:12:08 +0000] [1] [INFO] Using worker: gthread
[2025-12-04 02:12:08 +0000] [92] [INFO] Booting worker with pid: 92
[INFO] 04/Dec/2025 02:12:09 - Loading User config from: /home/mobsf/.MobSF/config.py
[INFO] 04/Dec/2025 02:12:35 -
  __  __      _    ____  _____      _  _   _  _
 |  V  | __ | |__/ ___||  ___|_   _| || | | || |
 | |\/| |/ _ \| '_ \___ \| |_  \ \ / / || |_| || |_
 | |  | | (_) | |_) |__) |  _|  \ V /|__   __|__   _|
 |_|  |_|\___/|_.__/____/|_|     \_/    |_|(_) |_|

[INFO] 04/Dec/2025 02:12:35 - Author: Ajin Abraham | opensecurity.in
[INFO] 04/Dec/2025 02:12:35 - Mobile Security Framework v4.4.3
REST API Key: 9e3b95e8d4367d44d60df5032e17fa1fca97caff94a10a813a7ae131e49ccb49
Default Credentials: mobsf/mobsf
[INFO] 04/Dec/2025 02:12:35 - OS Environment: Linux (debian 12 bookworm) Linux-6.12.25-amd64-x86_64-with-glibc2.36
[INFO] 04/Dec/2025 02:12:35 - Python Version: 3.13.7
[INFO] 04/Dec/2025 02:12:35 - CPU Cores: 2, Threads: 2, RAM: 1.93 GB
[INFO] 04/Dec/2025 02:12:35 - MobSF Basic Environment Check
[INFO] 04/Dec/2025 02:12:36 - Checking for Update.
[INFO] 04/Dec/2025 02:12:37 - No updates available.
```

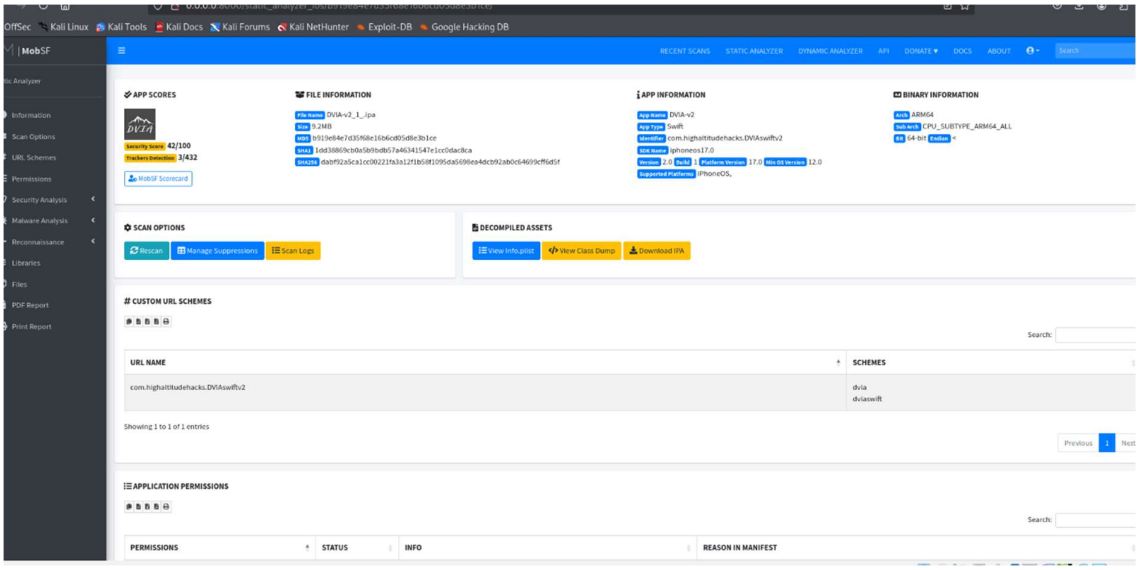
STEP 3:

- Login with the credentials with mobsf as user and password.
- Download the above IOS IPA file in kali.



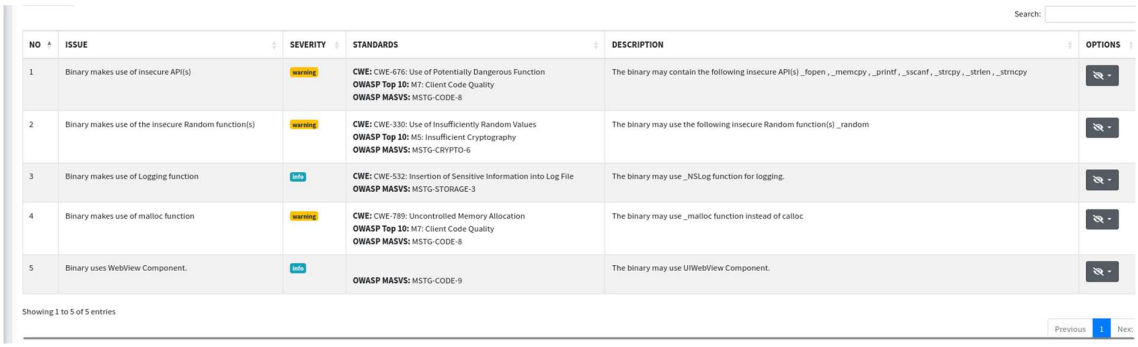
STEP 4:

• Drag and drop that IPA file in Mobsf and scan it.



STEP 4:

• Static report of IPA file and its vulnerabilities and issues listed below.



Search:

NO	ISSUE	SEVERITY	STANDARDS	DESCRIPTION	OPTIONS
1	Binary makes use of insecure API(s)	warning	**CWE:** CWE-676: Use of Potentially Dangerous Function **OWASP Top 10:** M7: Client Code Quality **OWASP MASVS:** MSTG-CODE-8	The binary may contain the following insecure API(s) _fopen , _memcpy , _printf , _sscanf , _strcpy , _strlen , _strncpy	
2	Binary makes use of the insecure Random function(s)	warning	**CWE:** CWE-330: Use of Insufficiently Random Values **OWASP Top 10:** M5: Insufficient Cryptography **OWASP MASVS:** MSTG-CRYPTO-6	The binary may use the following insecure Random function(s) _random	
3	Binary makes use of Logging function	info	**CWE:** CWE-532: Insertion of Sensitive Information into Log File **OWASP MASVS:** MSTG-STORAGE-3	The binary may use _NSLog function for logging.	
4	Binary makes use of malloc function	warning	**CWE:** CWE-789: Uncontrolled Memory Allocation **OWASP Top 10:** M7: Client Code Quality **OWASP MASVS:** MSTG-CODE-8	The binary may use _malloc function instead of calloc	
5	Binary uses WebView Component.	info	**OWASP MASVS:** MSTG-CODE-9	The binary may use UIWebView Component.	

Showing 1 to 5 of 5 entries

Previous 1 Next

References:

- https://developer.apple.com/documentation/security
- https://support.apple.com/guide/security/welcome/web
- https://developer.apple.com/xcode/
- https://mobsf.github.io/docs/

THANK YOU